DeepL

Subscribe to DeepL Pro to translate larger documents.
Visit www.DeepL.com/pro for more information.

Ministry of Justice and Security

FG Assessment Framework DPIA

Go directly to

1 Introduction

1.1 Purpose

1.2 Target group

1.3 Components of the assessment framework

1.4 Assessment levels and colors

2 Use of the FG DPIA Assessment Framework

2.1 Stakeholder involvement and privacy-by-design approach

2.2 Assessment of the aspects in the DPIA

2.3 DPIAs with a high impact on data subjects

FG Assessment Framework DPIA

Imprint

Project name	FG Assessment Framework DPIA
Project number	
Version	1.0 Meeting
location	The Hague
Project leaders	
Contact	Christel Van de Wal
	Data Protection Officer fg@minjenv.nl
	Turfmarkt 147 | 2511 DP The Hague PO Box 20301 | 2500 EH The Hague
Authors	Office FG JenV and AenM: Christel van de Wal and Shanta Singh
	The FG Assessment Framework DPIA was developed in collaboration with Jeroen Terstegge, Joris Hutter, and Kevin Elsinga, partners and advisors at Privacy Management Partners. www.pmpartners.nl

1 Introduction

The FG DPIA Assessment Framework can be used to assess in a uniform and transparent manner whether an intended or existing processing of personal data complies with applicable privacy legislation. The assessment framework is not exclusively focused on the GDPR, but also takes into account other relevant privacy laws and regulations and frameworks based on them. Although the assessment framework was primarily developed to support the Data Protection Officer (DPO) in assessing DPIA's, it can be used more broadly within the organization, including by managers (controllers) and DPIA drafters.

The assessment framework focuses primarily on the assessment of personal data processing within the operational processes of management teams or task organizations. DPIAs drawn up in the context of legislation or policy-making are not directly covered by this, as specific, separate assessment criteria apply to them. The assessment framework provides insight into the most important points for careful recording and implementation of a DPIA and thus supports the first and second lines, which are primarily responsible for its quality and completeness.

A DPIA is an important tool within the broader privacy law framework. It helps organizations to gain insight into the privacy risks of data processing in advance and to take appropriate measures to mitigate them. The FG DPIA Assessment Framework supports this process by providing insight into whether a DPIA is complete, accurate, and usable, and where improvements or additions are necessary.

The result of the DPIA assessment consists of:

- a score for each component;
- a report sheet with assessments, recommendations, and explanations;

The use of the FG DPIA Assessment Framework provides a structured overview that helps to improve the quality of DPIAs and strengthen privacy protection within JenV and AenM.

1.1 Purpose

The purpose of the FG Assessment Framework is to systematically and unambiguously assess whether a DPIA meets the requirements of Article 35, paragraphs 7, 9, 10, and 11 of the GDPR and the Model DPIA Government Service, which must be used to record the DPIA process. The following aspects are examined:

- the quality of the content: is the DPIA well-founded, complete, and clear to an informed outsider?
- the degree of compliance: have the rules and principles of the GDPR been properly applied?
- the accuracy of the risk assessment: are the negative risks of infringements of the rights and freedoms of data subjects described realistically?
- and the appropriateness of the control measures: are the measures sufficient to mitigate risks?

The assessment provides insight into the strengths and weaknesses of the DPIA. The first and second lines are primarily responsible for the quality of the DPIA. The DPO assesses this and can make specific recommendations to improve the quality of balanced data processing.

The assessment framework contributes to:

- a uniform working method for the DPO's within JenV and AenM;
- equivalent assessment of DPIAs, even if these are carried out in collaboration with other organizations;
- and greater clarity for managers (first line), DPIA drafters, and privacy officers (second line) about what is expected of a good DPIA.

1.2 Target group

The FG DPIA Assessment Framework has been developed for anyone involved in conducting, assessing, or supervising DPIAs within the Ministry of Justice and Security and the Ministry of the Interior and Kingdom Relations.

The main target groups are:

- Data Protection Officers (DPOs).
  They use the assessment framework to evaluate and compare DPIAs and to formulate recommendations that are in line with the GDPR and the context of JenV and AenM organizations.
- Privacy officers (second line).
  They can use the assessment framework to guide DPIA drafters in their work.
- DPIA drafters (domain specialists, first line)
  They can use the framework as a tool to better substantiate their DPIAs and assess the quality of their work before completion.
- Chain partners or collaborating organizations.
  In the case of joint data processing, the assessment framework helps to ensure a single, consistent assessment approach, thereby guaranteeing quality and transparency within the chain.
- Management.
  Management is assisted with balanced, sustainable data processing.

Organizations outside the Ministry of Justice and Security and the Ministry of the Interior and Kingdom Relations are free to use the FG DPIA Assessment Framework.

1.3 Components of the assessment framework

The assessment framework consists of four components:

1. DPIA quality assessment.
   This component assesses the systematic description, scope, processing purposes, parties, interests, and GDPR roles (Article 35(7)(a) GDPR).
2. Assessment of compliance + processing rules.
   This section assesses the necessity and proportionality of the processing (Article 35(7)(b) GDPR).
3. Assessment of risk to data subjects.
   This section assesses the risks for data subjects and whether a dialogue has been conducted with them (Article 35(7)(c) in conjunction with Article 35(9) of the GDPR).
4. Assessment of control measures.
   This section assesses the measures taken to address the risks identified in section 3 (Article 35(7)(d) GDPR).

1.4 Assessment levels and colors

Each component in the DPIA is assessed and the FG assigns a level and color to that assessment. The levels reflect the quality of the component. This allows you to see at a glance how well the DPIA scores.

Level 1 (not present)
The component is completely missing from the DPIA.

Level 2 (in progress)
The component is slightly inadequate (4/5). It is not good because it still contains non-compliance errors or control measures that are insufficient in view of the risks.

Level 3 (substantial)
The component is just sufficient (6). In other words, it is not wrong, but there is room for improvement.

Level 4 (advanced)
The component scores a solid pass (7/8). It is better than satisfactory. For example, the DPIA refers to best practices.

Please note: In some situations, a component cannot be assessed, for example if no automated decision-making takes place during processing. In these situations, the DPO assesses the component as N/A.

The descriptions of the various levels in the assessment framework serve as guidelines for the assessment. They do not constitute established standards or policy, but provide a structured framework for determining the degree of organization and functioning of a component. The levels support both the assessment and strategic choices, for example in prioritization and improvement.

Level 4 is the starting point and the desired target level. Level 3 indicates that the component in question is demonstrably and sufficiently organized. Deviation from the target level is possible, but requires a reasoned assessment of the nature, scope, and privacy risks of the processing.

2 The use of the FG DPIA Assessment Framework

Stakeholders can use the framework as a guide during the implementation of a DPIA process and thus ensure balanced data protection. The DPO can apply the FG Assessment Framework DPIA to assess compliance with the GDPR within the process described in the DPIA. The assessment of the various aspects described in the DPIA takes place in five levels (see section 1.4).

The Data Protection Officer (DPO) uses the DPO Assessment Framework DPIA to assess whether a DPIA meets the requirements of the GDPR and/or other applicable privacy legislation. The assessment framework highlights where a DPIA is strong or where it is still incomplete. In this way, the framework helps to improve the quality of the DPIA and reduce the risks to data subjects and the surrounding process. The DPO also uses the framework to engage in dialogue with the author and the process owner. The framework thus supports attention to and dialogue about quality, risks, and improvements.

2.1 Stakeholder involvement and privacy-by-design approach

Drawing up a DPIA requires a multidisciplinary approach. The DPIA specifies which internal and external stakeholders are involved in its preparation and how internal or external consultation or dialogue has been conducted with them. Internal stakeholders include:

- Process and subject matter experts who understand the importance of processing, how it works, and what issues there are or could be.
- The privacy officer, with specific knowledge of data protection to guide the DPIA process.
- The lawyer, with specific knowledge of substantive laws and the GDPR.
- The security officer, who can assess the information security aspects.
- The IT specialist who understands the capabilities and issues of the systems, infrastructure, and management.

External stakeholders include:

- A dialogue with the parties involved or the target group affected by the processing contributes to the assessment of the proportionality of the processing and to understanding whether the intended purpose can also be achieved with less intrusive processing of personal data. In addition, this dialogue helps to identify and assess privacy risks that might otherwise go unnoticed. Furthermore, a multidisciplinary approach or dialogue helps to create support for the processing.
- Chain partners. Input from chain partners helps to achieve a balanced chain approach.

Also indicate in the DPIA whether and how privacy by design has been applied in the design of the processing or the improvement of that processing. Have privacy-enhanced technologies been considered?

2.2 Assessment of the aspects in the DPIA

Each section of the DPIA contains a description for each level that can be used as an assessment tool. In practice, the content of a DPIA will not always correspond exactly to the description of a single level. In that case, the Data Protection Officer (DPO) will determine which level best fits the situation.

The descriptions for each level are indicative and do not constitute established standards or policy. For each assessment, the DPO explains why a particular level has been chosen and which elements are already in place.

When in doubt about the appropriate level, the following principles apply:

- if a component contains elements of a higher level but does not yet fully meet that level, the lower level is assigned;
- the DPO justifies this choice and describes which components are already moving towards a higher level.

This approach contributes to a transparent and consistent assessment of the DPIA. In the DPO's DPIA Assessment Framework spreadsheet, the DPO selects the level in the Supervisor score.

2.3 DPIAs with a high impact on data subjects

Processing operations with a high impact on the rights and freedoms of data subjects require a high level of protection and also place higher demands on the DPIA (process).

Processing operations that are expected to pose a high risk of harm to the organization also require a higher level of assessment. In such situations, the content of the DPIA is assessed at a higher desired level. The score given may therefore be lower than in a DPIA for which a lower desired level is expected.

FG Assessment Framework DPIA

Level 2 (in progress) results in a slight failure (4/5). It is not good; there are still non-compliance errors or control measures are too weak in view of the risks.

Level 3 (substantial) results in a pass (6). In other words, it is not wrong, but it could be better.

Level 4 (advanced) results in a 7/8. It is better than satisfactory. For example, reference is made to best practices.

Level 5 (mature) scores 9/10. It exceeds expectations, is detailed, and the measures go beyond what you would expect under the circumstances and according to best practices.

	GDPR principle	Level 1 (Not present)	Level 2 (In progress)	Level 3 (Substantial)	Level 4 (Advanced)	Level 5 (Complete)	Supervisor score	Numerical score	Description of assessed level	Recommendation
DPIA quality assessment	Systematic description	No description of the process or processing available.	General description of the process, without details about parties/GDPR roles or data flows.	Description of the most important process steps and parties involved/GDPR roles. Data flows and systems have been mapped to a limited extent.	Complete and regularly updated description of processes with parties involved/GDPR roles, systems, and data flows, including how process steps and systems depend on each other. The description is readable by a non-expert and a complete file is available.	Comprehensive and regularly updated process description with clear visual representation (flowchart), in which all parties/GDPR roles, systems, data flows, and privacy by design are fully elaborated, including how process steps and systems are interdependent.				
	Scope	No scope is described. It is unclear which data, systems, or processes are covered by the processing.	The scope is not explicitly mentioned but can only be (partly) deduced from the text. The description of the activities or data categories provides a general picture of the processing.	The scope is described in very general terms, for example, "the name of a system or process," without further definition.	The scope is clearly defined in the description. The elaboration is still incomplete and important elements are missing.	The scope is described completely and accurately. Not only is it specified what is included in the processing, but it is also explicitly stated what remains outside the scope.				
	Processing purpose	No processing purpose(s) has/have been formulated.	The purpose is described in broad or vague terms, for example 'for business operations', without any concrete definition.	There is a general description of the purpose, linked to certain activities or services, but important sub-purposes are still missing.	The processing purpose and any sub-purposes are clearly and fully described, with a distinction between different activities or categories.	The processing purpose has been fully elaborated and clearly formulated. For each activity and category, it has been established why the processing takes place and where the boundaries lie, so that the necessity and proportionality can be clearly deduced.				
	Parties involved in the DPIA process								☐ Privacy officer ☐ Process/subject matter expert ☐ Chain partners ☐ Legal matters	☐ Information security ☐ ICT ☐ PbD applied ☐ PET considered
Compliance assessment + processing rules	Basis	No legal basis; privacy information is missing.	There is a general reference to a basis (e.g., "on basis of the GDPR'), but without specifying what of the bases is applied.	There are one or more legal bases basis has been selected and designated, but the elaboration is limited or not fully appropriate to the processing. It is unclear whether the basis mentioned For each piece of data, a appropriate basis.	For all data (categories), there is a appropriate basis has been selected and designated, including any references to tasks or powers in substantive law.	The basis has been fully developed and accurately explained for each processing activity. There is a clear justification why this basis is the correct one. Special and criminal data are listed in a separate row.				
	Proportionality	There is no assessment of proportionality is specified.	There is a broad superficial statement that the processing is proportionate, without justification.	There is a concise explanation why the processing is proportionate to the purpose, with some examples/ arguments.	There is a clear assessment of the proportionality, whereby for each activity or data category has been elaborated on why processing is appropriate and not excessive.	There is a clear assessment of the proportionality, whereby for each activity or data category has been elaborated why processing is appropriate and not excessive. A distinction is also made distinction is made between proportionality with and without the measures result from the DPIA.				
	Subsidiarity	There is no assessment of subsidiarity is present.	In general terms indicated that there is no alternative, but this is not substantiated.	There is a brief explanation of why the objective cannot be achieved by other, less intrusive means can be achieved.	There is a clear assessment of subsidiarity. Alternative methods or means referred to as explained why these are less suitable .	There is a comprehensive and well-founded constructed assessment of subsidiarity. All relevant alternatives are investigated and documented, with clear reasoning as to why the chosen processing is the least intrusive way to achieve the goal.				
	Purpose limitation	There is no purpose limitation purpose test is carried out or the text is not appropriate for the question of whether there is purpose limitation.	It states in general terms that data for a specific purpose, but without delimitation or restriction.	The purpose limitation test is not structurally developed or there is not justified that this purpose limitation test has been waived.	Purpose limitation is structured, where the weighing of interests is clearly is apparent or falls under a clear reference is made to the applicable legal provisions why a purpose limitation test was not necessary.	Purpose limitation and basis are clearly distinguished from each other. If the data processing data used from another process, clearly indicate that a purpose limitation purpose test has been carried out with benchmark that other processes and how these processes are related interrelated.				

	GDPR principle	Level 1 (Not present)	Level 2 (In progress)	Level 3 (Substantial)	Level 4 (Advanced)	Level 5 (Complete)	Supervisor score	Numerical score	Description of assessed level	Recommendation
Compliance assessment + processing rules	Storage restriction	No usage and retention periods have been established or described.	There are general references to retention periods, for example 'as short as possible' or 'in accordance with legislation', without further specification. Terms of use are still completely missing.	Retention periods are mentioned, but their structure is not described. There is also an indication of how long data is actively used, but without full elaboration.	Terms of use and retention periods are described for each data category. With reference to the relevant articles of law, a distinction is made between the active use phase and the possible archiving phase.	Retention and usage periods are extensively and accurately defined for each data category. These are substantiated by legislation and regulations or practical requirements. In addition, it has been defined how data will be restricted after the end of the usage period (e.g., archiving or pseudonymization) and how it will be permanently deleted or anonymized after the retention period.				
	Information security	No security measures have been described or applied. It is unclear how the data is protected.	Reference is made to information security in general terms, for example, "system X is used," but without explanation or elaboration.	There is an initial description of information security measures, without insight into the actual situation.	The information security measures are clearly described and provide a clear picture of the technical protection within the processing.	The existing information security measures are described comprehensively and systematically. All relevant components (including technical and organizational context) are made clear, with concrete examples.				
	Rights of data subjects (including complaints)	It is unclear how those involved are informed about their rights. It is unclear how they can exercise these rights.	Reference is made in general terms to the rights of data subjects (e.g., "data subjects have a right of access"), but without further explanation or application.	It is described how data subjects can exercise their rights. The elaboration remains limited.	All rights of data subjects are listed and there is a clear description of how data subjects can exercise these rights. It is clear which roles/functions are responsible for handling GDPR requests (RASCI).	Data subjects have the option of exercising their rights themselves (online access, correction, deletion).				
	Transfer outside the EEA	No attention has been paid to transfers outside the EEA.	Attention is paid to transfers outside the EEA, but this is not sufficiently elaborated. The chain for which responsibility applies (processor, sub-processor) is unclear.	It is stated that personal data is transferred to recipients outside the EEA. The entire chain is identified (including sub-processors). Measures have been described to ensure that the transfer takes place lawfully.	A DTIA has been carried out. The transfer outside the EEA is fully described. The countries involved are named. The elaboration is sufficiently detailed to enable a proper assessment of the risks and lawfulness.	A DTIA has been carried out with the involvement of experts who are familiar with the law of the country to which the transfer is made.				
	Automated decision-making/profiling/AI	No attention is paid to automated decision-making/profiling/AI.	Automated decision-making/profiling/AI takes place, but this is only mentioned without any description of its nature, scope, and consequences.	Automated decision-making/profiling/AI is described with an initial explanation of the consequences for those involved. The reasons why this is lawful are stated.	Specific assessments have been carried out, such as FRIA's, IAMA's, or AI impact assessments. The most important risks and safeguards have been recorded.	Automated decision-making has been assessed thoroughly and in depth. In addition to FRIA's, IAMA's, and AI impact assessments, extensive consideration has been given to risks, ethical considerations, and (legal) safeguards. Transparency towards data subjects and review of outcomes have been fully elaborated.				
Assessment of risks for stakeholders	Risks for stakeholders	No risks to stakeholders have been described (e.g., only risks to the organization).	Risks are mentioned, but in general terms and without a clear link to reality or the specific processing. Probability and impact are not taken into account.	All relevant risks are mentioned in terms of impact/consequences for the data subject, but without an assessment of the probability of their occurrence and their impact on those involved.	Risks are described on the basis of realistic scenarios. A risk matrix is included in which the risks are listed. The analysis clarifies which risks carry the most weight. Gross and net risks are made clear.	In addition to the detailed elaboration of the risks for those involved, the organizational risks are also identified. The risks are ranked according to priority.				
	Dialogue with the target group	No explanation is provided as to how the risks were assessed from the perspective of the target group and why this was not done in some cases.	The perspective of the target group has been taken into account in a general sense, but without active consultation.	Consultation took place with the target group or their representatives. The insights gained were taken into account exclusively when assessing the risks and determining measures.	Consultation took place with the target group or their representatives. The insights gained were used to assess the purpose and necessity of the processing more accurately and also guided the assessment of risks and choices for measures.	A clear and broad dialogue was conducted with the target group or their representatives. Their views have been added to the DPIA (as an appendix). Reasons are given as to why certain issues raised during the consultation were or were not addressed.				
Assessment of control measures	Control measures Please note that these are additional measures taken in response to the DPIA. They are not measures that are already in place in general or were already included in the project plan.	No control measures have been described or established.	Reference is made to measures in general terms (e.g., "we take appropriate security measures") without any concrete explanation. Measures may also be described that are not appropriate for the risks identified.	Measures are described in general terms that are appropriate to the identified risks.	There is a clear description of measures that correspond to the identified risks. Appropriate measures have been identified for each risk and there is sufficient detail to assess whether the risks are actually being mitigated and to what extent there are still residual risks.	Measures and residual risks have been comprehensively and systematically elaborated. For each risk, it has been determined which specific measures will be implemented, how these measures will reduce the likelihood or impact, and how the effectiveness of the measure will be ensured.				

This brochure is published by:
Ministry of Justice and Security December 2025